Brew & Bloom Coffee Co. - PE1

Owner: Almin, Del Rosario, Gan
Reviewer:
Contributors:
Release Date: Wed Oct 28 2026

Executive Summary

High level system description

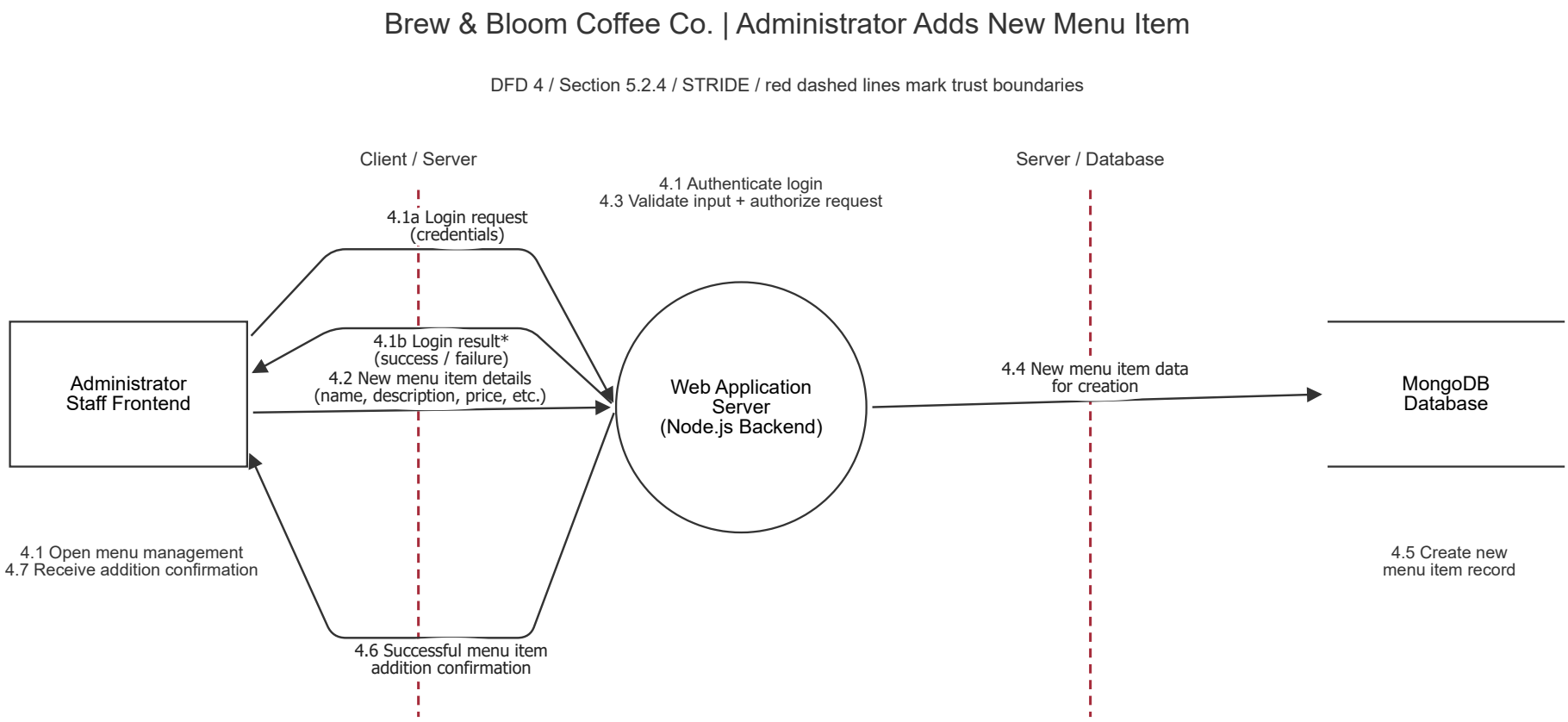
PE1 Part 1: all four workflows from section 5.2. Boundaries follow section 5.1; threat titles, descriptions and affected-component mappings follow Table 2; severity uses Table 3 row counts. Source: Threat Model Document - Coffee Ordering Web App.pdf. Shared component threats are retained in each diagram.

Summary

Total Threats	128
Total Mitigated	0
Total Open	128
Open / Critical Severity	0
Open / High Severity	24
Open / Medium Severity	96
Open / Low Severity	8

Administrator Adds New Menu Item

Section 5.2.4: Administrator Adds New Menu Item. 5 directed data transfers, including the Administrator login request, three components and two trust boundaries. Internal actions are notes. No payment gateway is specified for this workflow. All Table 2 mappings are retained for present shared components; severity follows Table 3 counts. No implementation security controls are independently verified. The separate login-result response is a modeling assumption: the source does not explicitly specify its payload. It carries success/failure only; no session implementation is asserted.



* Login-result response is a modeling assumption; authentication and authorization checks remain on the server.
Shared-component threats follow Table 2. Payment service is not part of this workflow.

Administrator Adds New Menu Item

Administrator Staff Frontend (Actor)

Description: Step 4.1: log into the staff interface and navigate to menu management. Step 4.2: enter and submit new menu item details. Step 4.7: receive addition confirmation. The staff frontend is untrusted. All Table 2 mappings are retained for this shared component, including threats concerning other workflows. A separate login-result response is included as an explicit modeling assumption, rather than an additional specification requirement.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
97	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
98	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
99	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	

Web Application Server (Node.js Backend) (Process)

Description: Step 4.1 login implies backend authentication of the Administrator. Step 4.3: validate new menu item input and authorize Administrator request. Step 4.4: send data to MongoDB for creation. Step 4.6: confirm successful addition to Administrator. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
100	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
101	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
102	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	
103	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
104	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
105	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
106	Application Code/Configuration Tampering	Tampering	Medium	Open	T-007; 6 Table 3 checks	Malicious modification of the application’s source code, server configurations, or environment variables could introduce backdoors or disable security features.	
107	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	
108	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
109	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
110	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
111	Application Code and Configuration Disclosure	Information disclosure	Medium	Open	T-012; 6 Table 3 checks	Exposure of source code, server configurations, environment variables, or API keys.	
112	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
113	Web Application Server DoS	Denial of service	Medium	Open	T-014; 7 Table 3 checks	An attacker could flood the Web Application Server with excessive requests, making it unavailable.	
114	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	
115	Customer to Staff Privilege Escalation	Elevation of privilege	High	Open	T-016; 10 Table 3 checks	A customer could exploit a vulnerability to gain unauthorized access to Barista, Manager, or Administrator functionalities.	
116	Barista/Manager to Administrator Privilege Escalation	Elevation of privilege	High	Open	T-017; 10 Table 3 checks	A Barista or Manager could exploit a vulnerability to gain Administrator privileges.	
117	Horizontal Privilege Escalation	Elevation of privilege	Medium	Open	T-018; 6 Table 3 checks	Gaining unauthorized access to another user's account within the same privilege level.	

MongoDB Database (Store)

Description: Step 4.5: create the new menu item record from backend-supplied data. MongoDB trusts backend identity. A separate database acknowledgement is not specified. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
118	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
119	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
120	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
121	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
122	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
123	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
124	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	
125	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
126	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
127	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
128	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	

4.1a Login request (credentials) (Data Flow)

Description: Administrator sends login credentials from the staff frontend to the web application server in step 4.1. Opening menu management remains a frontend action; validation and authorization in step 4.3 remain backend processing.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

4.1b Login result* (success / failure) (Data Flow)

Description: MODELING ASSUMPTION: a separate authentication-result response returns login success or failure from the web application server to the staff frontend. Section 5.2 specifies login/authentication but does not explicitly describe this response. No token, cookie, session protocol, or credential store is assumed. Authentication and operation-specific authorization checks remain server processing; business data is returned on its existing separate flow.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

4.2 New menu item details (name, description, price, etc.) (Data Flow)

Description: Administrator enters and submits details after logging in and navigating to menu management in step 4.1.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

4.4 New menu item data for creation (Data Flow)

Description: After input validation and authorization in step 4.3, backend sends data to MongoDB. MongoDB creates the record in step 4.5.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

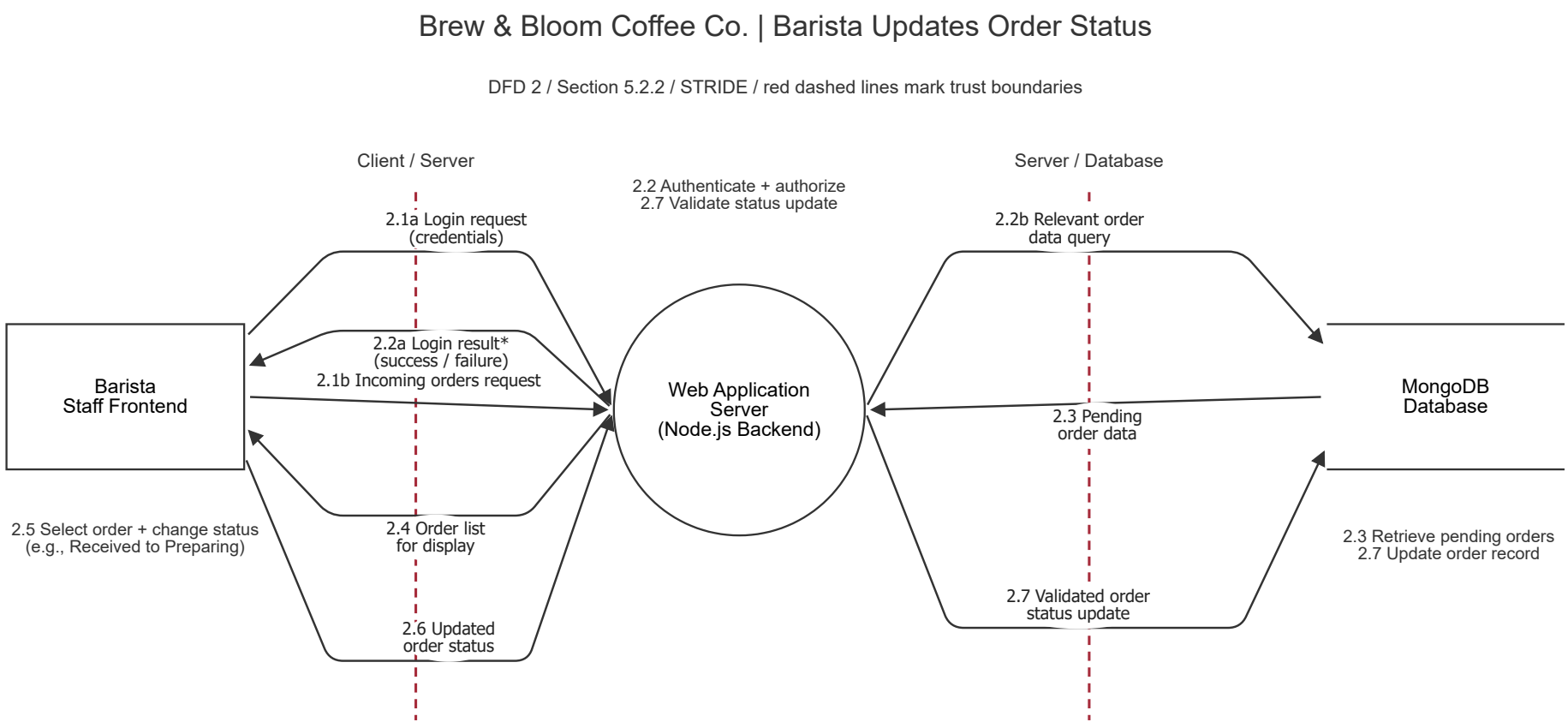
4.6 Successful menu item addition confirmation (Data Flow)

Description: Backend confirms successful addition. Administrator receives confirmation in step 4.7. No extra database response is invented.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Barista Updates Order Status

Section 5.2.2: Barista Updates Order Status. 8 directed data transfers, with separate login and business requests, three components and two trust boundaries. Internal actions are notes. No payment gateway is specified for this workflow. All Table 2 mappings are retained for present shared components; severity follows Table 3 counts. No implementation security controls are independently verified. The separate login-result response is a modeling assumption: the source does not explicitly specify its payload. It carries success/failure only; no session implementation is asserted.



* Login-result response is a modeling assumption; authentication and authorization checks remain on the server.
Shared-component threats follow Table 2. Payment service is not part of this workflow.

Barista Updates Order Status

Barista Staff Frontend (Actor)

Description: Steps 2.1, 2.4-2.6: log in and request incoming orders, display the list, select an order and change its status, then submit the update. The staff frontend is untrusted. All Table 2 mappings are retained for this shared component, including threats concerning other workflows. A separate login-result response is included as an explicit modeling assumption, rather than an additional specification requirement.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
33	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
34	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
35	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	

Web Application Server (Node.js Backend) (Process)

Description: Step 2.2: authenticate and authorize the Barista, then query relevant orders. Step 2.4: return the list. Step 2.7: validate the submitted status and update the database record. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
36	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
37	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
38	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	
39	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
40	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
41	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
42	Application Code/Configuration Tampering	Tampering	Medium	Open	T-007; 6 Table 3 checks	Malicious modification of the application’s source code, server configurations, or environment variables could introduce backdoors or disable security features.	
43	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	
44	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
45	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
46	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
47	Application Code and Configuration Disclosure	Information disclosure	Medium	Open	T-012; 6 Table 3 checks	Exposure of source code, server configurations, environment variables, or API keys.	
48	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
49	Web Application Server DoS	Denial of service	Medium	Open	T-014; 7 Table 3 checks	An attacker could flood the Web Application Server with excessive requests, making it unavailable.	
50	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	
51	Customer to Staff Privilege Escalation	Elevation of privilege	High	Open	T-016; 10 Table 3 checks	A customer could exploit a vulnerability to gain unauthorized access to Barista, Manager, or Administrator functionalities.	
52	Barista/Manager to Administrator Privilege Escalation	Elevation of privilege	High	Open	T-017; 10 Table 3 checks	A Barista or Manager could exploit a vulnerability to gain Administrator privileges.	
53	Horizontal Privilege Escalation	Elevation of privilege	Medium	Open	T-018; 6 Table 3 checks	Gaining unauthorized access to another user’s account within the same privilege level.	

MongoDB Database (Store)

Description: Step 2.3: retrieve and return pending order data. Step 2.7: receive the validated order-status update. MongoDB trusts calls from the backend identity. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
54	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
55	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
56	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
57	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
58	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
59	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
60	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	
61	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
62	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
63	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
64	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	

2.1a Login request (credentials) (Data Flow)

Description: Step 2.1: staff frontend sends login credentials to the web application server. The business request is represented by a separate data flow. Authentication and authorization remain internal backend checks.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.2a Login result* (success / failure) (Data Flow)

Description: MODELING ASSUMPTION: a separate authentication-result response returns login success or failure from the web application server to the staff frontend. Section 5.2 specifies login/authentication but does not explicitly describe this response. No token, cookie, session protocol, or credential store is assumed. Authentication and operation-specific authorization checks remain server processing; business data is returned on its existing separate flow.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.1b Incoming orders request (Data Flow)

Description: Step 2.1: after logging in, the staff frontend sends the incoming orders request to the web application server. Login credentials are shown on a separate arrow.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.2b Relevant order data query (Data Flow)

Description: After authenticating and authorizing the Barista, backend queries MongoDB for relevant order data.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.3 Pending order data (Data Flow)

Description: MongoDB retrieves pending order data and returns it to the backend.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.4 Order list for display (Data Flow)

Description: Backend sends the order list to Barista for display.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

2.6 Updated order status (Data Flow)

Description: After locally selecting an order and changing its status in step 2.5, Barista sends the updated order status to backend.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

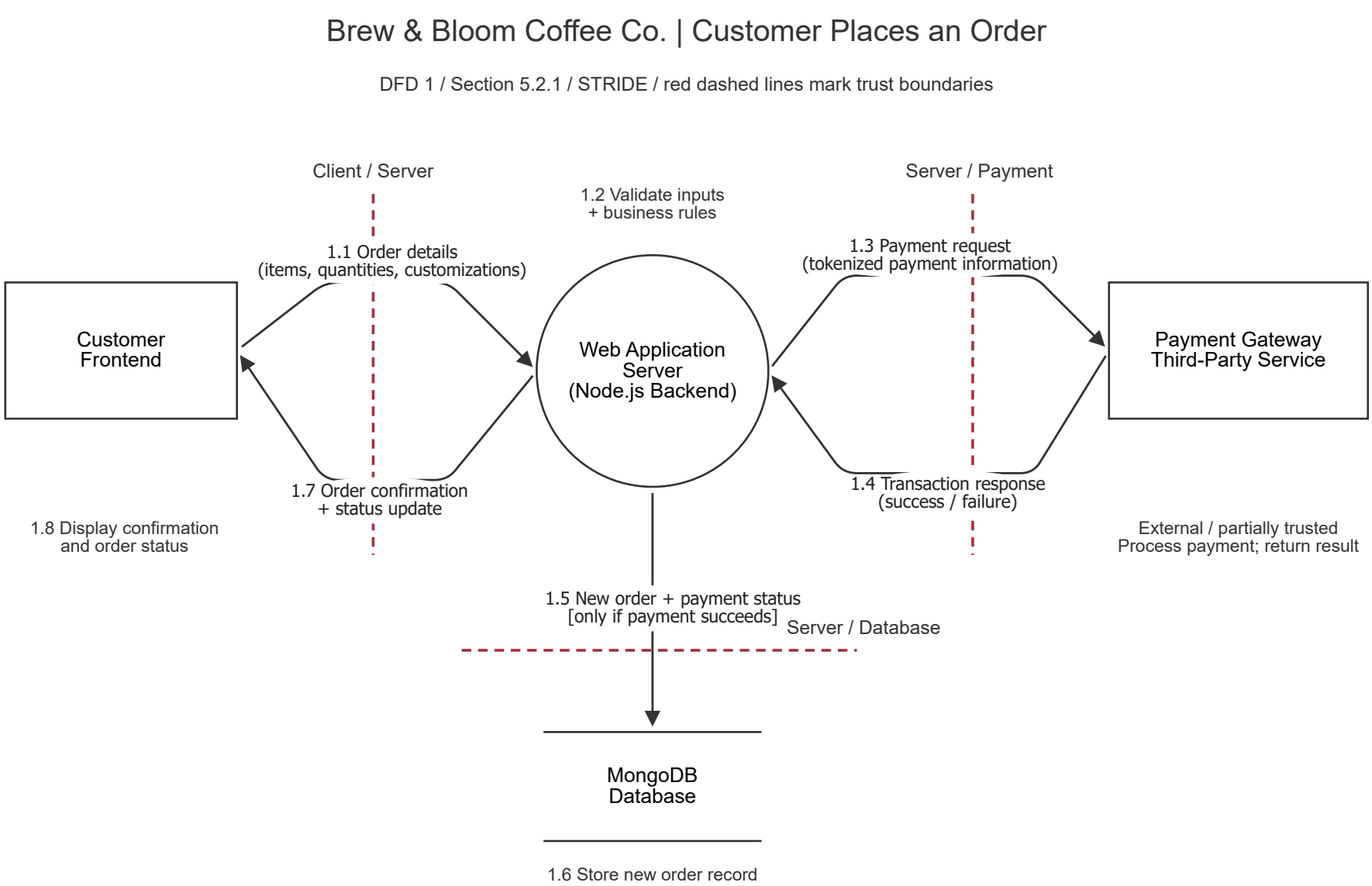
2.7 Validated order status update (Data Flow)

Description: Backend validates the status update and updates the order record in MongoDB.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Customer Places an Order

Section 5.2.1 steps 1.1-1.8. Five directed transfers, four components, three boundaries. Validation/storage/display are notes. All Table 2 mappings retained for present shared components, including threats concerning other workflows. STRIDE capitalization follows Threat Dragon. Severity uses Table 3 check counts. Security requirements are not independently verified implementation claims.



Payment failure: no new order write is shown.
Error handling beyond the transaction response is not specified.

Customer Places an Order

Customer Frontend (Actor)

Description: Steps 1.1 and 1.8: select/customize items, submit details, display confirmation/status. Untrusted frontend. All Table 2 mappings retained for this shared frontend, including staff-facing threats.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
2	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
3	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	

Web Application Server (Node.js Backend) (Process)

Description: Step 1.2: validate inputs and business rules (availability/customizations). Initiate payment, validate response, then write order only after success. All Table 2 mappings retained for the shared backend, including threats concerning staff/menu/report workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
5	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
6	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	
7	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
8	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
9	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
10	Application Code/Configuration Tampering	Tampering	Medium	Open	T-007; 6 Table 3 checks	Malicious modification of the application’s source code, server configurations, or environment variables could introduce backdoors or disable security features.	
11	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	
12	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
14	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
15	Application Code and Configuration Disclosure	Information disclosure	Medium	Open	T-012; 6 Table 3 checks	Exposure of source code, server configurations, environment variables, or API keys.	
16	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
17	Web Application Server DoS	Denial of service	Medium	Open	T-014; 7 Table 3 checks	An attacker could flood the Web Application Server with excessive requests, making it unavailable.	
18	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	
19	Customer to Staff Privilege Escalation	Elevation of privilege	High	Open	T-016; 10 Table 3 checks	A customer could exploit a vulnerability to gain unauthorized access to Barista, Manager, or Administrator functionalities.	
20	Barista/Manager to Administrator Privilege Escalation	Elevation of privilege	High	Open	T-017; 10 Table 3 checks	A Barista or Manager could exploit a vulnerability to gain Administrator privileges.	
21	Horizontal Privilege Escalation	Elevation of privilege	Medium	Open	T-018; 6 Table 3 checks	Gaining unauthorized access to another user’s account within the same privilege level.	

Payment Gateway Third-Party Service (Actor)

Description: Steps 1.3-1.4: process tokenized payment and return success/failure. External and partially trusted. Backend validates received data. Table 2 lists no threats affecting this service.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

MongoDB Database (Store)

Description: Step 1.6: store order and payment status. Trusts calls from backend identity. Table 2 mappings retained for the shared database.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
22	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
23	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
24	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
25	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
26	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
27	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	
28	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	
29	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
30	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
31	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
32	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	

1.1 Order details (items, quantities, customizations) (Data Flow)

Description: Customer submits order details. Server validates inputs and business logic in 1.2.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

1.3 Payment request (tokenized payment information) (Data Flow)

Description: Backend initiates payment through the external gateway. Secured communication channel as specified in section 5.1.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

1.4 Transaction response (success / failure) (Data Flow)

Description: Gateway returns transaction response; backend validates the external data. Secured communication channel as specified in section 5.1.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

1.5 New order + payment status [only if payment succeeds] (Data Flow)

Description: Backend writes order/payment status only after success. Step 1.6 stores the record. No database acknowledgement is specified.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

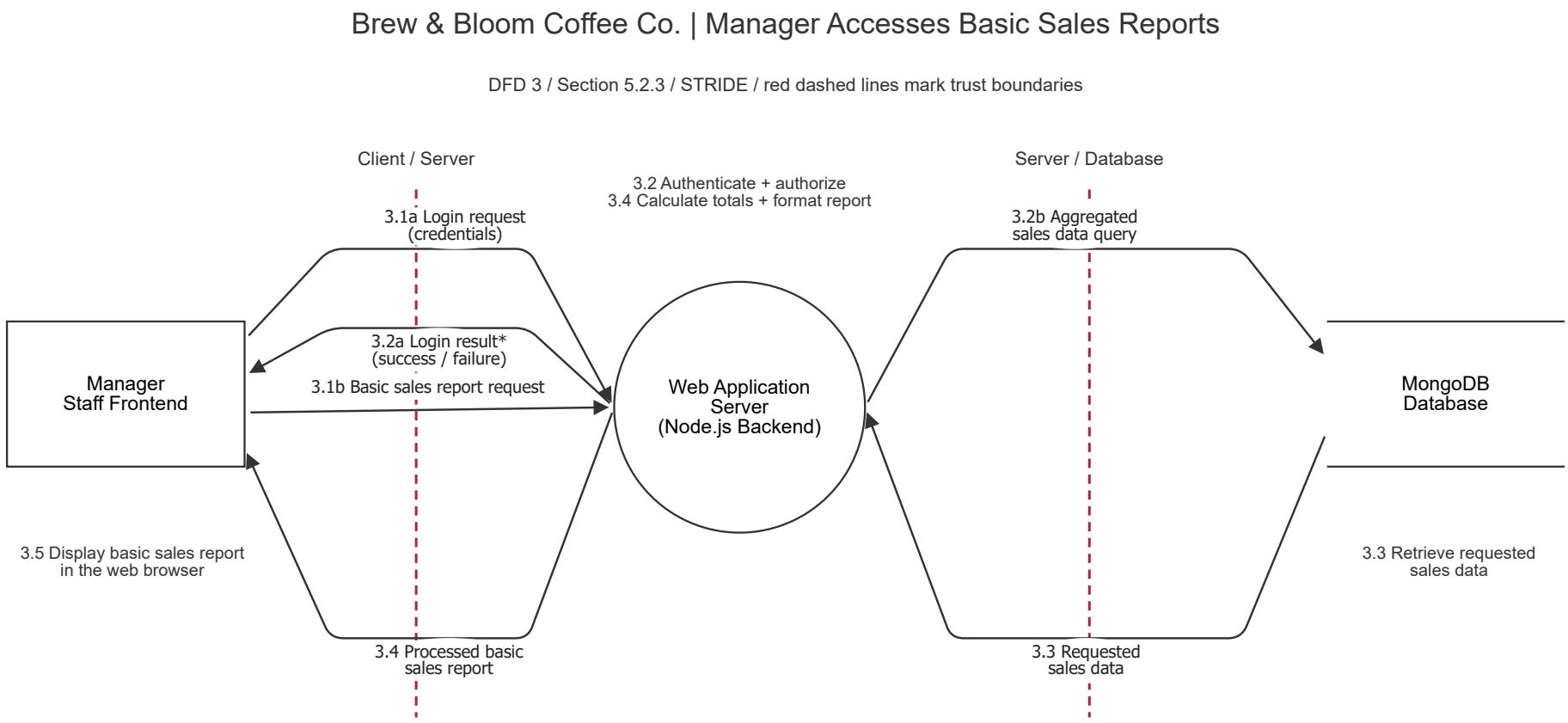
1.7 Order confirmation + status update (Data Flow)

Description: Backend returns confirmation/status. Frontend displays it in 1.8.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Manager Accesses Basic Sales Reports

Section 5.2.3: Manager Accesses Basic Sales Reports. 6 directed data transfers, with separate login and business requests, three components and two trust boundaries. Internal actions are notes. No payment gateway is specified for this workflow. All Table 2 mappings are retained for present shared components; severity follows Table 3 counts. No implementation security controls are independently verified. The separate login-result response is a modeling assumption: the source does not explicitly specify its payload. It carries success/failure only; no session implementation is asserted.



* Login-result response is a modeling assumption; authentication and authorization checks remain on the server.
Shared-component threats follow Table 2. Payment service is not part of this workflow.

Manager Accesses Basic Sales Reports

Manager Staff Frontend (Actor)

Description: Steps 3.1 and 3.5: log in, request basic sales reports, and display the report in the browser. The staff frontend is untrusted. All Table 2 mappings are retained for this shared component, including threats concerning other workflows. A separate login-result response is included as an explicit modeling assumption, rather than an additional specification requirement.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
65	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
66	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
67	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	

Web Application Server (Node.js Backend) (Process)

Description: Step 3.2: authenticate and authorize Manager, then query aggregated sales data. Step 3.4: process returned data, calculate totals, format it, and return the basic sales report. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
68	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
69	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
70	Web Application Server Spoofing	Spoofing	Medium	Open	T-003; 5 Table 3 checks	An attacker might set up a fraudulent web server to phish user credentials or intercept sensitive data.	
71	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
72	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
73	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
74	Application Code/Configuration Tampering	Tampering	Medium	Open	T-007; 6 Table 3 checks	Malicious modification of the application’s source code, server configurations, or environment variables could introduce backdoors or disable security features.	
75	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	
76	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
77	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
78	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
79	Application Code and Configuration Disclosure	Information disclosure	Medium	Open	T-012; 6 Table 3 checks	Exposure of source code, server configurations, environment variables, or API keys.	
80	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
81	Web Application Server DoS	Denial of service	Medium	Open	T-014; 7 Table 3 checks	An attacker could flood the Web Application Server with excessive requests, making it unavailable.	
82	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	
83	Customer to Staff Privilege Escalation	Elevation of privilege	High	Open	T-016; 10 Table 3 checks	A customer could exploit a vulnerability to gain unauthorized access to Barista, Manager, or Administrator functionalities.	
84	Barista/Manager to Administrator Privilege Escalation	Elevation of privilege	High	Open	T-017; 10 Table 3 checks	A Barista or Manager could exploit a vulnerability to gain Administrator privileges.	
85	Horizontal Privilege Escalation	Elevation of privilege	Medium	Open	T-018; 6 Table 3 checks	Gaining unauthorized access to another user’s account within the same privilege level.	

MongoDB Database (Store)

Description: Step 3.3: retrieve requested sales data and return it to backend. MongoDB trusts calls from backend identity. All Table 2 mappings are retained for this shared component, including threats concerning other workflows.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
86	Customer Account Spoofing	Spoofing	Medium	Open	T-001; 5 Table 3 checks	An attacker could impersonate a legitimate customer to place fraudulent orders or access their order history.	
87	Staff Account Spoofing	Spoofing	Medium	Open	T-002; 5 Table 3 checks	An attacker could impersonate staff to manipulate order statuses, access sales reports, or modify menu items and application configurations.	
88	Order Data Tampering	Tampering	Medium	Open	T-004; 7 Table 3 checks	An attacker could modify order details (e.g., items, quantities, prices, status) in transit or at rest.	
89	Menu Data Tampering	Tampering	Medium	Open	T-005; 6 Table 3 checks	An attacker could alter menu item data (e.g., prices or descriptions) before it is stored in the database.	
90	Sales Report Tampering	Tampering	Medium	Open	T-006; 5 Table 3 checks	Unauthorized individuals could alter sales data in the MongoDB Database, leading to falsified reports.	
91	Fraudulent Order Repudiation	Repudiation	Medium	Open	T-008; 5 Table 3 checks	A customer could deny placing an order if insufficient logging and non-repudiation controls are in place.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
92	Staff Action Repudiation	Repudiation	Medium	Open	T-009; 5 Table 3 checks	Staff members (Barista, Manager, Administrator) could deny performing actions if audit logs are insufficient, not immutable, or can be tampered with.	
93	Customer PII Disclosure	Information disclosure	High	Open	T-010; 10 Table 3 checks	Unauthorized access to customer names, contact details, delivery addresses, and order history.	
94	Staff Credential Disclosure	Information disclosure	High	Open	T-011; 10 Table 3 checks	Exposure of usernames, passwords, or session tokens for staff members due to insecure storage or unencrypted transmission.	
95	Sales Data Disclosure	Information disclosure	Medium	Open	T-013; 7 Table 3 checks	Unauthorized access to sales reports or underlying aggregated sales data.	
96	MongoDB Database DoS	Denial of service	Low	Open	T-015; 2 Table 3 checks	Malicious or poorly optimized queries could overload the database, making it unresponsive.	

3.1a Login request (credentials) (Data Flow)

Description: Step 3.1: staff frontend sends login credentials to the web application server. The business request is represented by a separate data flow. Authentication and authorization remain internal backend checks.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3.2a Login result* (success / failure) (Data Flow)

Description: MODELING ASSUMPTION: a separate authentication-result response returns login success or failure from the web application server to the staff frontend. Section 5.2 specifies login/authentication but does not explicitly describe this response. No token, cookie, session protocol, or credential store is assumed. Authentication and operation-specific authorization checks remain server processing; business data is returned on its existing separate flow.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3.1b Basic sales report request (Data Flow)

Description: Step 3.1: after logging in, the staff frontend sends the basic sales report request to the web application server. Login credentials are shown on a separate arrow.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3.2b Aggregated sales data query (Data Flow)

Description: Backend authenticates and authorizes Manager, then queries MongoDB for aggregated sales data.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3.3 Requested sales data (Data Flow)

Description: MongoDB retrieves requested sales data and returns it to backend.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

3.4 Processed basic sales report (Data Flow)

Description: Backend processes the data (calculates totals and formats for display), then responds to Manager. Manager displays it in step 3.5.

Number	Title	Type	Severity	Status	Score	Description	Mitigations